CYBERSECURITY PORTFOLIO | NIST CYBERSECURITY FRAMEWORK (CSF) ALIGNED

Incident Report Analysis: DoS Attack Remediated

Author / Role: Syed Yasir Shah, Cybersecurity Analyst

Organization: Multimedia Solutions Inc.

Framework: NIST CSF (Identify, Protect, Detect, Respond, Recover)

Incident Type: Denial of Service (ICMP Flood / Ping Flood)

1. Executive Incident Overview

A multimedia company providing web design, graphic design, and social media marketing solutions to small businesses experienced a major network outage caused by a Denial of Service (DoS) attack. The attack targeted the internal corporate network using an ICMP packet flood (Ping Flood) transmitted through an unconfigured perimeter firewall. Network services were unresponsive for approximately two hours before the incident response team isolated the malicious traffic, suspended non-essential network services, and recovered critical workflows.

> **Security Incident Summary:** Root Cause Analysis: The internal disruption was made possible by an unconfigured perimeter firewall that failed to rate-limit incoming ICMP traffic or inspect source IP validity. An attacker flooded the infrastructure with echo request packets, exhausting network bandwidth and router processing queues, resulting in complete denial of internal services.

2. Incident Report Analysis (NIST CSF Matrix)

The table below documents the security event and outlines strategic improvements across the five core functions of the NIST Cybersecurity Framework (CSF v1.1):

NIST CSF Function	Incident Findings & Security Implementation Strategy
Summary	The multimedia organization experienced a two-hour denial of service (DoS) security event when internal network services suddenly stopped responding. The incident response team identified that an attacker launched an ICMP packet flood attack through an unconfigured perimeter firewall. The team mitigated the attack by dropping incoming ICMP traffic, halting non-critical network services to relieve congestion, and restoring mission-critical operations.
Identify	An unauthorized external threat actor targeted the company's internal infrastructure via an ICMP flood (Ping Flood) attack. All internal network segments and client-facing business services were impacted for two hours. Root cause analysis revealed an unconfigured firewall lacking rate-limiting and access control lists (ACLs). Moving forward, regular network security audits, vulnerability assessments, asset management inventories, and access privilege reviews must be conducted to proactively uncover configuration gaps.

Protect	To protect internal assets and prevent future network saturation, the cybersecurity team configured firewall rule sets to enforce ICMP rate limiting and implemented a network-based Intrusion Detection/Prevention System (IDS/IPS) to inspect packet payloads and filter malicious ICMP traffic based on suspicious signatures. Additional protections include network segmentation (separating client design staging from corporate infrastructure) and ongoing employee cybersecurity awareness training.
Detect	To ensure rapid discovery of anomalous behaviors and unauthorized traffic spikes, the security team configured source IP address verification (anti-spoofing / Reverse Path Forwarding) on the perimeter firewall to detect spoofed packets. Furthermore, automated network monitoring software was deployed with alerting thresholds to detect abnormal traffic volumes, bandwidth saturation, and protocol anomalies in real time.
Respond	During an active incident, response personnel will immediately isolate impacted network segments and enforce automated firewall drops on malicious traffic sources. Non-critical services will be offlined systematically to preserve system resources for core operational assets. The incident response team will analyze network packet captures and firewall/SIEM logs to determine attack vectors, document forensics, and report critical findings to executive management and regulatory authorities as required.
Recover	Full recovery is achieved by restoring impacted network resources following a prioritized continuity sequence: critical customer-facing services and databases are brought online and validated first. Once monitoring confirms incoming malicious ICMP streams have fully ceased, non-critical services are re-enabled. Post-incident reviews (tabletop retrospectives) will be conducted to refine firewall configurations, tune IDS/IPS rules, and update business continuity documentation.
Reflections / Notes	• Defense-in-Depth Value: Relying solely on perimeter hardware is insufficient without tailored configuration. A single misconfigured rule on an edge device can nullify internal availability. • Network Availability as a Security Pillar: While confidentiality and integrity remained intact (no data breach or data exfiltration occurred), the Availability pillar of the CIA Triad was severely broken, causing financial disruption and lost operational hours. • Continuous Monitoring: Implementing automated network telemetry and rate limiting transforms reactive fire-fighting into proactive, automated threat containment.

3. Technical Countermeasures & Architecture Hardening

The cybersecurity team implemented four distinct technical controls to address the vulnerability:

- 1. ICMP Rate Limiting: Configured on the edge firewall to restrict ICMP echo request packets to a maximum baseline (e.g., 5-10 pings per second per source IP), preventing ping-flooding from exhausting network bandwidth.

- 2. Source IP Address Verification (Unicast RPF): Enabled strict Reverse Path Forwarding (uRPF) to cross-reference packet headers against the routing table, discarding spoofed IP traffic at the interface boundary.
- 3. Network Monitoring & Telemetry: Deployed real-time bandwidth and protocol analyzers with threshold alerts for unusual ICMP/UDP volume spikes.
- 4. Inline IDS/IPS Deployment: Configured intrusion prevention signature rules (e.g., Snort/Suricata rules) to automatically drop malformed, oversized, or high-frequency ICMP packets before reaching the internal switch fabric.

4. Ongoing Recommendations & Security Roadmap

- • Baseline Configuration Reviews: Mandate quarterly configuration audits for all edge firewalls, switches, and load balancers to ensure rules align with organizational hardening standards.
- • Service Priority Mapping: Formulate a formalized Business Impact Analysis (BIA) that explicitly documents which services are deemed 'critical' (client databases, public websites) vs 'non-critical' (internal collaboration tools) during an active DDoS event.
- • Upstream ISP DDoS Mitigation: Coordinate with the internet service provider (ISP) for upstream filtering and blackholing capabilities should attack volume exceed local line rates.